Papeles de trabajo: investigación del incidente

Guía de lectura

Cada papel presenta objetivo, material, procedimiento, resultado y conclusión. Los códigos al final permiten encontrar el soporte técnico.

Sesión remota y verificación de identidad · PT-20 · página 3

Aumento de permisos y lectura de clientes · PT-21 · página 4

Transferencia externa y comparación de tamaños · PT-22 · página 5

Cambios de órdenes, duplicidad y respaldos · PT-23 · página 6

Seguimiento de la alerta crítica · PT-24 · página 7

Integridad de registros y fiabilidad de horarios · PT-25 · página 8

Son seis papeles individuales. La integración del equipo y la revisión del estudiante siguen pendientes.

Papeles de trabajo: investigación del incidente

Responsable y custodio designado de las copias: Anthony Samuel Ordoñez Son, carné 2401002033. Preparación asistida por Codex. Revisión y firma del estudiante pendientes. Límite del análisis: 15 de octubre de 2026, 23:59:59, hora de Guatemala (UTC−6).

Procedencia y método

Se sigue la plantilla de papeles de trabajo de la Guía de entregables, página 3. Cada papel explica qué se examinó, cómo, qué se obtuvo y qué falta para concluir. Los códigos PT permiten encontrar el papel; los códigos E identifican evidencia; T identifica una prueba y Q una consulta a la base de datos. Son referencias de localización.

La fuente de los sucesos es el Proyecto del curso, páginas 3–5. No se recibieron registros originales de RedNova, sus fechas de extracción, custodios o huellas digitales. Los resultados de consultas proceden de datos ficticios preparados para el ejercicio. Un «control de prueba» es un caso diseñado para comprobar si el método detecta o excluye una condición conocida; no es otro suceso del ataque.

Las consultas se ejecutaron previamente en SQL Server 2022 Developer, versión 16.0.4305.5, usando una cuenta de auditor con permiso de lectura. Se compararon dos bases de laboratorio con 16 tablas, 91,800 filas y 18 relaciones entre tablas; los resultados repetidos coincidieron. Después se revisaron los archivos y se recalcularon conteos e intervalos con Python. Esta comprobación verifica el ejercicio, sin corroborar de forma independiente el incidente.

Las fechas de ejecución y las huellas SHA-256 están en resultados/Ejecuciones_v1.csv. Una huella permite comprobar si cambió un archivo; no autentica el suceso descrito en él. La custodia de las copias se registra en formulario_custodia.md. El método reproducible está en analizar_I4.py; las instrucciones para repetir consultas, en ../04_SQL/README.md. Los nombres de carpetas son referencias técnicas, no etapas del ataque.

La evaluación global de riesgos y controles corresponde a María José Aldana Culajay y sigue pendiente. Los umbrales del laboratorio son reglas del ejercicio, no políticas acreditadas de RedNova. Las recomendaciones externas y sus páginas están en las fuentes adjuntas.

PT-20 · Sesión remota y verificación de identidad

Objetivo. Examinar la sesión remota reportada y determinar si puede afirmarse uso indebido o incumplimiento de una política.

Material revisado. Acceso remoto del expediente (E-02), Proyecto, páginas 4–5. El caso identifica la cuenta ext_ops_04: es un nombre de usuario, no la identidad de quien inició sesión. La sesión de las 02:17 se reporta sin autenticación multifactor, una comprobación adicional a la contraseña.

Procedimiento y muestra. La consulta de permisos examinó 120 cuentas ficticias, 30 con privilegios elevados. La consulta de horarios comparó cada cuenta con su actividad del 7 al 13 de octubre, exigiendo al menos cinco observaciones en tres días. Se incluyeron actividades nocturnas habituales para evitar clasificarlas como anómalas solo por la hora. Posteriormente se cotejaron los archivos completos y sus huellas.

Resultado. Se seleccionaron 18 cuentas ficticias: ocho sin verificación adicional, cuatro compartidas, tres con revisión de permisos de más de 180 días y tres sin fecha de revisión. Entre ellas está la cuenta que reproduce el caso. La consulta horaria seleccionó tres sesiones: una representa el evento del expediente y dos fueron diseñadas como controles anómalos. No son tres sesiones demostradas del ataque.

Conclusión y límite. No concluyente sobre uso malicioso o infracción real. Faltan política aplicable, excepciones, configuración histórica de acceso, titular de la cuenta, dispositivo y registro original. Se recomienda solicitarlos y conectar la sesión con acciones concretas. La revisión final de accesos queda pendiente de la responsable de controles.

Localización técnica. Consultas de permisos y horarios (Q-02 y Q-03); pruebas T-21/T-22. Resultados en resultados/Q-02.csv y resultados/Q-03.csv. Usuarios y sesiones de origen en ../04_SQL/datos/v2/.

PT-21 · Aumento de permisos y lectura de clientes

Objetivo. Evaluar la autorización y el volumen de lectura, conservando como desconocida la identidad no aportada.

Material revisado. El caso reporta aumento de permisos a las 02:26 y lectura de 31,840 registros a las 02:31. La evidencia de lectura corresponde a la bitácora de base de datos resumida en el expediente (E-03), páginas 4–5.

Procedimiento y muestra. Una consulta buscó asignaciones de permisos vigentes sin solicitud de autorización o vencimiento documentados. Otra comparó lecturas con el máximo habitual de cada cuenta, usando al menos cinco días de referencia y un umbral de tres veces ese máximo. Se revisaron las siete asignaciones seleccionadas, las dos lecturas obtenidas y sus campos desconocidos.

Resultado. Seis asignaciones eran controles ficticios incompletos; una reproducía el aumento de permisos del caso, sin cuenta ni autorización conocidas. Una lectura ficticia de control, de 20,000 filas frente a un máximo habitual de 1,000, activó la regla. La lectura de 31,840 quedó sin evaluación de exceso porque se desconoce la cuenta y su patrón habitual. No hay sesión, dirección de red o identificador de acceso que conecte la cuenta remota con esa lectura. Cinco minutos de cercanía no prueban el vínculo.

Conclusión y límite. No concluyente sobre autorización, exceso o responsable de la lectura del incidente. Solicitar el registro original de la base de datos, la sentencia ejecutada, los objetos consultados, la identidad efectiva, la aplicación y los permisos de ese momento. El caso de control valida la regla; no demuestra la hipótesis de ataque.

Localización técnica. Consultas de permisos y lectura (Q-04/Q-05), pruebas T-23/T-24; resultados del mismo nombre en resultados/. La tabla de permisos ficticios está en ../04_SQL/datos/v2/Privilegios.csv.

PT-22 · Transferencia externa y comparación de tamaños

Objetivo. Determinar si el volumen reportado permite afirmar una extracción de clientes sin autorización.

Material revisado. Transferencia externa aproximada de 1.6 gigabytes (GB) a las 02:35, Proyecto, páginas 4–5 (E-04). La consulta de tráfico compara origen, destino, protocolo y puerto con cinco días de referencia y un umbral de tres veces el máximo habitual.

Procedimiento. Se revisaron los tres resultados de tráfico. Después se calculó el tamaño de siete campos de los primeros 31,840 clientes ficticios: identificador, nombre, departamento, plan, fecha de alta, estado y clasificación. Se compararon dos formatos de texto: valores separados por comas (CSV) y un objeto por línea con nombres de campo (JSON Lines). Se usó codificación UTF-8, sin compresión, adjuntos ni datos adicionales de transporte. El cálculo se hizo en memoria; no se creó un supuesto archivo robado.

Resultado. El registro que representa al caso conserva como desconocidos bytes exactos, direcciones, puerto, protocolo, duración y contenido. Los otros dos flujos son controles: uno de 1,200,000,000 bytes excede su referencia; el otro no tiene clasificación. La repetición posterior de esta consulta conservó sus tres filas. Diez escenarios adicionales comprobaron la selección y las etiquetas, incluido el límite exacto de tres veces el volumen habitual, sin modificar los datos.

Comparación de magnitudes. Los siete campos ocupan **2,058,909 bytes** en CSV y **5,115,483 bytes** en JSON Lines. Los 1.6 GB decimales equivalen a 777.11 y 312.78 veces esos tamaños. Suponer una sola copia de las 31,840 filas exigiría unos 50,251 bytes por fila. Escenarios hipotéticos de 1,000, 10,000 y 50,000 bytes por fila darían 0.03184, 0.3184 y 1.592 GB.

El anexo explora además 1.6 gibibytes (GiB), unidad binaria distinta del GB decimal: produciría factores de 834.42 y 335.84 y unos 53,957 bytes por fila. El caso dice GB; esa alternativa no sustituye su dato. Los cuatro minutos entre lectura y transferencia no permiten calcular velocidad, porque no se conoce la duración del envío.

Conclusión y límite. No concluyente sobre extracción no autorizada o correspondencia entre las dos cifras. Un envío único de estos campos ficticios es mucho menor; podrían existir archivos, repetición, otros datos o tráfico legítimo. Solicitar contenido u objetos enviados, dueño del destino, equipo y proceso de origen, autorización y registros originales de red; compararlos con la lectura y la actividad habitual.

Localización técnica. Consultas de lectura y tráfico (Q-05/Q-06), pruebas T-24/T-25. Cálculos en resultados/I4/Volumen_31840_I4_v1.json; comprobación posterior en resultados/Correcciones_revision_P1_v1/SQL_Q06/. Datos ficticios: ../04_SQL/datos/v2/Clientes.csv y TransferenciasRed.csv.

PT-23 · Cambios de órdenes, duplicidad y respaldos

Objetivo. Distinguir órdenes de cambios y establecer qué se necesita para evaluar integridad y efecto económico.

Material y procedimiento. El caso reporta 216 órdenes modificadas a las 02:42 (E-05), sin campos ni montos. Se revisaron todas las filas de la consulta de cambios entre las 02:17 y 03:42 y se compararon con el historial ficticio, campo por campo. Otra consulta agrupó órdenes por cliente, minuto, plan, monto y canal, excluyendo canceladas. La consulta de respaldos distinguió programación, ejecución y restauración.

Resultado de órdenes. Hay 216 cambios en 216 órdenes distintas. Los 144 cambios de monto y 72 de estado fueron supuestos del ejercicio, todos a las 02:42. Las 216 filas desconocen usuario, sesión y vía del cambio. Como muestra, el primer cambio de la primera orden pasa de Q200.00 a Q220.00; son valores ficticios y no una pérdida real de Q20.00. La otra consulta obtuvo diez pares candidatos, veinte órdenes numeradas de 1001 a 1020, sin coincidencia con las 216 anteriores. No demuestra doble cobro.

Resultado de respaldos. Se registran nueve programaciones, ocho con ejecución entre el 7 y el 14 de octubre y ninguna ejecución registrada el día 15. La reducción de 8.2 a 3.2 GiB, aproximadamente 60.976 %, es ficticia. La ejecución adicional de junio y la restauración del 1 de julio también son datos simulados. No se realizó una restauración real.

Conclusión y límite. No concluyente sobre integridad, fraude, autor o pérdida económica. Tampoco queda acreditada la afirmación de datos intactos. Se necesitan historial original, autorizaciones, identificadores de transacción, facturas, cobros y comparación con un respaldo limpio y el sistema financiero. Antes de evaluar recuperación hacen falta los objetivos del negocio: tiempo máximo de restablecimiento y pérdida temporal de datos tolerable.

Localización técnica. Consultas de cambios, posibles duplicados y respaldos (Q-07/Q-08/Q-09), pruebas T-26/T-27/T-28. Cotejo en resultados/I4/Analisis_ordenes_I4_v1.json. Historial ficticio en ../04_SQL/datos/v2/HistorialOrdenes.csv.

PT-24 · Seguimiento de la alerta crítica

Objetivo. Evaluar si están documentados la recepción, asignación, primera acción, escalamiento y cierre de la alerta.

Material y procedimiento. El Proyecto, páginas 4–5, reporta una alerta crítica a las 03:18 sin cierre documentado (E-07). Se examinaron seis alertas de laboratorio: una representa el caso y cinco son controles. La consulta seleccionó cuatro con información incompleta. Se cotejó la cronología y se recalcularon los intervalos.

Resultado. La alerta que representa el caso no tiene responsable asignado, primera acción, cierre ni nota. Es el registro con identificador de alerta 6, cuarto registro de datos del resultado. De la sesión a la alerta hay 61 minutos; de la alerta a la caída, 24; de la caída a la solicitud de recuperación, 23. Ninguno permite medir atención o cierre. La solicitud de las 04:05 no puede tomarse como primera acción de seguridad.

Criterio de evaluación. Las buenas prácticas de respuesta del Instituto Nacional de Estándares y Tecnología de Estados Unidos (NIST) recomiendan clasificación, seguimiento y escalamiento. Las fuentes adjuntas precisan versión y apartados. No se aportó una política adoptada por RedNova ni un plazo contractual con el que afirmar incumplimiento.

Conclusión y límite. No concluyente sobre falla operativa. Sí falta documentación suficiente para acreditar seguimiento. Solicitar el registro original de atención, sus acciones y aceptación de cierre; después probar el circuito con una alerta controlada y objetivos previamente aprobados. Esta es la observación sobre seguimiento de alertas, aún sin aprobación como hallazgo.

Localización técnica. Consulta de alertas (Q-11), prueba T-30; resultado resultados/Q-11.csv, campo AlertaID=6. Intervalos en resultados/I4/Intervalos_I4_v1.json.

PT-25 · Integridad de registros y fiabilidad de horarios

Objetivo. Examinar si los registros podrían modificarse y qué límites existen para reconstruir la secuencia.

Material y procedimiento. La advertencia previa número 8, página 3 del Proyecto, plantea que ciertos administradores podrían alterar registros. No equivale a la evidencia E-08, que trata de respaldos. Se revisaron tres contextos de permisos del laboratorio y cinco intentos rechazados al auditor. Se examinaron también los trece eventos y escenarios hipotéticos de relojes adelantados o atrasados cinco, diez y quince minutos.

Resultado de permisos. El usuario ficticio denominado admin_bitacora_lab tenía permisos de consultar, modificar y eliminar filas de la bitácora. El usuario de comparación y el auditor solo podían consultar entre los permisos examinados. Se comprobó capacidad, sin modificar ni borrar la bitácora. La cuenta administradora que ejecutó la comprobación no identifica a un responsable del incidente. Los cinco rechazos al auditor tampoco prueban que no existan otros administradores.

Resultado temporal. No hay relojes originales verificados ni correcciones demostradas. Solo la sesión remota identifica una cuenta. La cronología es una selección de trece sucesos; los intervalos entre ellos no demuestran pérdida o borrado de registros. Para comprobarlo se necesitan secuencias, contadores, reglas de conservación y copias independientes.

Como ejercicio, los veinte minutos entre cambios de órdenes e instalación de software pasarían a 10–30 con errores independientes de cinco minutos por reloj; a 0–40 con diez; y a −10–50 con quince. Un valor negativo indica inversión del orden. No son estimaciones del error real. Un desfase constante compartido se cancela al restar; no se ha comprobado que las marcas procedan del mismo reloj.

Conclusión y límite. No concluyente sobre manipulación, permisos o preservación en RedNova. Solo quedó comprobada la capacidad del administrador ficticio. Se recomienda obtener permisos históricos, registros originales y configuración de conservación y tiempo; preservar una copia separada y protegida; y probar generación, recepción y rechazo de modificaciones en un entorno autorizado. Esta es la observación sobre protección de registros, aún no un hallazgo definitivo.

Localización técnica. Consulta de permisos (Q-S01), prueba T-32; resultados/Q-S01.csv, Concesiones_SQL.csv y Permisos_rechazos.csv. Escenarios de horarios en resultados/I4/Sensibilidad_relojes_I4_v1.csv. Fuentes externas: conservación e integridad de evidencia, en la bibliografía adjunta.

Revisión pendiente

El estudiante debe poder seguir una muestra desde el caso hasta el resultado y explicar sus límites. Quedan pendientes la revisión humana, la firma y la revisión cruzada del equipo. Estos papeles no acreditan entrevistas, ensayos ni acciones ejecutadas en RedNova.